

MOCK EXAM Paper

Question 1

Web applications commonly include user-generated content such as comment sections, forms, and feedback pages. When these inputs are not properly handled, attackers can exploit vulnerabilities to execute malicious scripts, compromise user sessions, and bypass authentication or authorization controls.

(a)

Describe how an attacker could exploit a **Cross-Site Scripting (XSS)** vulnerability in a **user comment section** to hijack another user's session. Differentiate between **stored XSS** and **reflected XSS**, providing **one practical example** of each.

(b)

With reference to **secure development practices**:

1. (i) Explain how **input validation** and **output encoding** help mitigate **injection-style attacks**. Why is **input validation alone insufficient** for preventing XSS attacks?
2. (ii) Identify **two OWASP Top 10 risks** directly related to **poor authentication or access control**, and propose **one specific mitigation strategy** for each.

Question 2

Malware and email-based attacks remain highly effective due to a combination of automated exploitation techniques and human trust. Understanding how different malware types propagate and how email authentication mechanisms function is critical to defending organizational environments.

(a)

Compare the **propagation methods** and **primary objectives** of a **worm** and **ransomware**. Explain why ransomware often relies on **human interaction**, whereas worms typically do not.

(b)

Email spoofing continues to undermine organizational trust and enable fraud:

1. (i) Explain how **SPF** verifies sender legitimacy and how **DKIM** ensures message integrity. Why is **DMARC necessary** even when both SPF and DKIM are implemented?

2. (ii) Outline a **Business Email Compromise (BEC)** scenario targeting **payroll processing**. Recommend **two defensive measures** one **technical** (e.g., DMARC enforcement) and one **procedural** (e.g., dual approval for payroll changes).

Question 3

Public and private networks are increasingly interconnected, exposing users to interception and manipulation attacks. Weak wireless security and poor network segmentation can allow attackers to compromise sensitive data and internal systems.

(a)

Using the **CIA Triad**, explain how a **Man-in-the-Middle (MitM)** attack on an **unsecured café Wi-Fi network** can compromise both **confidentiality** and **integrity**. Include a realistic consequence such as **credential theft** or **transaction manipulation**.

(b)

You are tasked with securing a **small business environment** that includes **remote workers**, a **public website**, **internal staff systems**, and **guest Wi-Fi**:

1. (i) Design a **network segmentation strategy** using a **firewall**, **DMZ**, and **VLANs**, and justify the placement of each component.
2. (ii) Explain why **WPA3** provides stronger wireless security than **WPA2**, mentioning **two specific improvements** such as the **SAE handshake** or **forward secrecy**.

Question 4

Cryptography is fundamental to securing modern communications and protecting sensitive data. Secure protocols rely on combining different cryptographic techniques to achieve confidentiality, integrity, and authentication efficiently.

(a)

Explain why modern protocols such as **TLS 1.3** use a **hybrid cryptographic model**. Contrast the roles of **AES (symmetric encryption)** and **RSA/ECC (asymmetric encryption)** in establishing a secure communication channel.

(b)

Considering real-world cryptographic implementations:

1. (i) Explain why **Electronic Codebook (ECB)** mode is insecure for encrypting **structured data** such as employee databases or images. Use a **conceptual example** to illustrate **pattern leakage**.
2. (ii) Describe how a **digital signature** provides **authentication, integrity, and non-repudiation**, including the steps involving **hashing** and **asymmetric key operations**.

Question 5

Digital forensics investigations must follow a structured methodology to ensure that evidence remains intact, reliable, and legally admissible throughout the investigation and potential court proceedings.

(a)

Outline the **six-phase digital forensics investigation workflow**, emphasizing why **evidence preservation** (e.g., write-blockers) and **cryptographic hashing** (SHA-256) are essential for **legal admissibility**.

(b)

During an **insider threat investigation** involving suspected **USB data theft**:

1. (i) Identify **three Windows forensic artifacts** that could demonstrate file copying to a removable drive (e.g., **USBSTOR registry keys, .lnk files, Volume Shadow Copies**).
2. (ii) Explain why **MD5** is considered insecure for forensic hashing today, referring to **collision resistance** and a real-world example such as **Google's 2017 SHA-1 collision demonstration**.

Question 6

Modern organizations rely on continuous monitoring and structured incident response to detect and respond to advanced cyber threats such as ransomware. Intrusion detection systems and SIEM platforms play a key role in early detection and analysis.

(a)

Differentiate between **signature-based** and **anomaly-based** detection methods used in **IDS/IPS systems**. Discuss **one advantage and one limitation** of each when detecting **zero-day ransomware**.

(b)

Following a **ransomware alert**:

1. **(i)** Map the first three phases of the **NIST Incident Response Lifecycle Preparation, Detection & Analysis, and Containment** to **concrete actions** performed by a **Security Operations Center (SOC)**.
2. **(ii)** Explain how a **SIEM system** (e.g., Splunk or ELK Stack) supports incident analysis by **correlating logs** from endpoints, firewalls, and authentication servers. Provide **two specific log sources** used to detect **lateral movement**.